

Pentest Report: http://dvwa:80

Executive Summary

The target host `dvwa` (172.18.0.3) running Apache httpd 2.4.25 was identified as highly vulnerable. Multiple

Findings

1. Service Identification

- **Port**: 80/tcp
- **Service**: HTTP
- **Version**: Apache httpd 2.4.25 ((Debian))
- **Evidence**: Nmap service detection confirmed the specific version, which is known to have historical vulnerabilities.

2. Web Application Vulnerabilities (Nikto Scan)

The Nikto scanner identified significant risks:

- **Directory Traversal**: The application allows traversal of directories (`../..`), potentially exposing sensitive files.
- **Header Injection**: Multiple Content-Type header injection vectors were found, allowing attackers to manipulate headers.
- **Other Issues**: 16 distinct items reported as errors or vulnerabilities during the scan.

3. SQL Injection (sqlmap)

- **Vulnerability Type**: SQL Injection
- **Location**: Login functionality (`/login.php`)
- **Status**: Confirmed Exploitable
- **Evidence**: sqlmap successfully executed SQL queries and extracted data using tamper scripts, indicating a critical flaw.

Conclusion

The target `dvwa` presents a severe security risk due to the combination of outdated software versions and